Handoff 45: Invitation tokens out of addresses and logs (master run WE7, SEC-06)

Date: 2026-11-09 (America/Toronto)
Written by: Claude Code (implementer), in a separate git worktree
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request (#53), not merged, not deployed. **No migration, no new dependency.** Changes the invitation link a parent copies.

> **How to use this file:** upload it alone, or with `docs/plan/independent-learners.md`. The pull request diff is the source of truth (`build.md` section 14).

Starter prompt for the chat assistant

```
You are reviewing SEC-06 for Python Academy: invitation links used to carry their secret
token in
the query string (/?invite=...), which servers, proxies and request logs record. They now
carry it
after '#' (/#invite=...), which browsers never send. Check that old links still work, that
the token
leaves the address bar at once, and whether anything else could still record it.
```

Run plan details

Field	Value
Stage	WE7, second part: SEC-06
Base	`main`, at `1dc4b59`, after #51 merged
Part 2 boxes relied on	**None**
Merge order	Any. Conflicts only in `docs/run-log.md`, with other PRs from tonight

1. Step 0

No PR open except #52 (SEC-05, tonight). Worktree `../python-academy-sec06`; the main folder was not switched.

2. Handoff record

Field	Value
Task	Keep invitation tokens out of URLs and request logs
Human goal	An invitation can't be used by someone who only reads a log
Non-goals	Changing how tokens are made, stored (only a SHA-256 digest is stored, already) or how long they last (7 days)
Data and compatibility	**Links made before this deploy still work** until they expire
Deployment status	Not requested

Files changed

File	Change
`backend/app/main.py`	`POST /api/invitations` returns `/#invite=<token>`
`frontend/app/academy.tsx`	Reads the token after `#`, or from `?invite=` for older links, then clears the address as before
`backend/tests/test_academy.py`, `frontend/tests/academy.spec.ts`	New tests; the recorded link format updated
`docs/plan/site-design.md`	The link format, in the list of things a move to `/app` touches

3. Security note

What it fixes: opening `/?invite=<token>` sent the token to the web server, so Render's request logs, and anything in between, recorded it. Whoever read a log could have used an unexpired, unused invitation, as long as they could also sign in with the invited email. The email check already limited that.

What it does now: a browser keeps what follows `#` to itself. The page reads it, keeps it in `sessionStorage` for the Google sign-in round trip (as before), and removes it from the address at once.

Already in place: `Referrer-Policy: no-referrer`, a stored digest instead of the token, single use, 7 days, the email check.

What it does not cover: the link itself, wherever a parent pastes it (a chat, an email). That is how invitations work. And **links already made** still have the token in the query until they expire. Anything already in Render's logs stays there for Render's log retention.

4. Decisions and why

Decision	Options considered	Reason	Who decided
Token after `#`	A short code typed in; a POST from a form	Same link a parent copies today, no new step for learners	Implementer
Keep accepting `?invite=`	Refuse it	Links made in the last 7 days keep working	Implementer

5. Bugs found and how they were fixed

None.

6. How it was tested

Command	Result
Backend, SQLite	**895 passed, 11 skipped**
`npx tsc --noEmit` and `npm run build`	OK
`CI=1 npx playwright test tests/academy.spec.ts`	**35 passed**, including the old `?invite=` link and the new `#invite=` one
PostgreSQL and the full browser suite	In CI on this PR

The new browser test records every request the page makes from opening the link to enrolling, and checks no request address contains the token. Only the enrol request has it, in its body.

Deliberate-break controls (each undone; files matched saved copies byte for byte afterwards)

What I broke	Tests that failed
B1. The API puts the token back in the query	**1**
B2. The page ignores the part after `#`	**1**
B3. The page leaves the token in the address	**1**

7. Known limitations

- Older links keep the token in the query until they expire.

- Render's existing logs may hold old tokens. They expire within 7 days of being made, and are single use.

8. Live checks for you

After deploying, as a parent: create an invitation and check the link has `#invite=`. Open it in a private window: the address should change to `/` at once, and sign-in and enrolment should work as before.

9. Questions for you

None.

10. For the docs sync

Where	What
Backlog	SEC-06 `in_review` (#53, handoff 45)
Stage table	"45. Invitation tokens | SEC-06 | in_review (#53, handoff 45)"

11. Next concrete action

Review and merge.

12. Removing the worktree safely

From the **main** folder, after this PR is merged:

```
cd /Users/DEV/Projects/python-academy
git -C ../python-academy-sec06 status --short   # expect nothing
git worktree remove ../python-academy-sec06
git worktree prune
git branch -d sec/invite-tokens
```